



ASSESSMENT COVERSHEET

Attach this coversheet as the cover of your submission. All sections must be completed.

Section A: Submission Details

Programme : Bachelor Of Information Technology (Hons) In Computer System Security
Course Code & Name : IKB21403 - VULNERABILITY ANALYSIS
Course Lecturer(s) : Nor Adani Kamal Mohamad Nasir
Submission Title : LAB 2 (CORE ANALYST SKILL)
Deadline : Day 07 Month 06 Year 2026 Time 11.59pm
Penalties :

- 5% will be deducted per day to a maximum of four (4) working days, after which the submission will **not** be accepted.
- Plagiarised work is an Academic Offence in University Rules & Regulations and will be penalised accordingly.

Section B: Academic Integrity

Tick (✓) each box below if you agree:

- | | |
|-------------------------------------|--|
| ☒ | I have read and understood the UniKL's policy on Plagiarism in University Rules & Regulations. |
| ☒ | This submission is my own, unless indicated with proper referencing. |
| ☒ | This submission has not been previously submitted or published. |
| ☒ | This submission follows the requirements stated in the course. |

Section C: Submission Receipt

(must be filled in manually)

Office Receipt of Submission

Date & Time of Submission (stamp)	Student Name(s)	Student ID(s)
	1 HAZIQ DANIAL BIN NOR AZAN	52215225213

Student Receipt of Submission

This is your submission receipt, the only accepted evidence that you have submitted your work. After this is stamped by the appointed staff & filled in, cut along the dotted lines above & retain this for your record.

Date & Time of Submission (stamp)	Course Code	Submission Title	Student ID(s) & Signature(s)

Contents

1. Objective & Methodology	3
2. Finding 1: Samba Badlock Vulnerability	4
2.1 CVE Information	4
2.2 CVSS Score & Vector Breakdown	4
2.3 CWE Mapping	5
2.4 Exploitability Analysis in Lab Environment	5
3. Finding 2: SSL Version 2 and 3 Protocol Detection (POODLE)	6
3.1 CVE Information	6
3.2 CVSS Score & Vector Breakdown	6
3.3 CWE Mapping	7
3.4 Exploitability Analysis in Lab Environment	7
4. Finding 3: VNC Server Weak Password	8
4.1 CVE Information	8
4.2 CVSS Score & Vector Breakdown	8
4.3 CWE Mapping	9
4.4 Exploitability Analysis in Lab Environment	10
5. Summary & Comparison	11
5.1 Key Learning: CVSS Score $\neq$ Actual Business Risk	11

1. Objective & Methodology

The objective of Lab 2 is to train analysts to understand vulnerability findings through manual research rather than blindly trusting automated scanner output. This lab involves selecting 3 vulnerabilities from Lab 1, researching them on CVE.org and NVD, breaking down the CVSS vector string, mapping each finding to a CWE, and evaluating whether each vulnerability is actually exploitable in the lab environment.

Three vulnerabilities were selected from Lab 1 scan results, covering different vulnerability categories:

- Finding 1: Samba Badlock Vulnerability (CVE-2016-2118) — Service/Protocol vulnerability
- Finding 2: SSL Version 2 and 3 Protocol Detection (CVE-2014-3566 / POODLE) — Cryptographic vulnerability
- Finding 3: VNC Server Weak Password — Authentication/Configuration vulnerability

Key Learning: CVSS Score does not equal actual business risk. A vulnerability with a high CVSS score may not be exploitable in a specific environment depending on factors such as whether the service is running, whether the port is reachable, and whether the attacker has the required position on the network.

2. Finding 1: Samba Badlock Vulnerability

2.1 CVE Information

CVE ID	CVE-2016-2118
Vulnerability Name	Samba Badlock — SAM/LSAD Protocol Man-in-the-Middle
CVE Published Date	April 12, 2016
Affected Software	Samba versions prior to 4.2.11 / 4.3.8 / 4.4.2
Source	CVE.org + NVD (nvd.nist.gov/vuln/detail/CVE-2016-2118)
Description (NVD)	The MS-SAMR and MS-LSAD protocol implementations in Samba accept authentication of inadequate levels. A man-in-the-middle attacker can downgrade the authentication level to CONNECT and take over the DCE/RPC connection to gain access to the SAM database.

2.2 CVSS Score & Vector Breakdown

CVSS Version	CVSS v3.0
CVSS Base Score	7.5 (HIGH)
CVSS Vector String	CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

CVSS Vector String Breakdown:

Metric	Value	Explanation
Attack Vector (AV)	Network (N)	Exploitable remotely over the network — no physical access needed
Attack Complexity (AC)	High (H)	Requires man-in-the-middle position on the network — harder to achieve
Privileges Required (PR)	None (N)	Attacker does not need any prior account/credentials on the target
User Interaction (UI)	Required (R)	A legitimate user must initiate an SMB connection for the attack to work
Scope (S)	Unchanged (U)	The vulnerability does not allow attacker to affect other components
Confidentiality (C)	High (H)	Full read access to SAM database including password hashes
Integrity (I)	High (H)	Attacker can modify data in the SAM database
Availability (A)	High (H)	Can disable critical services on the target

2.3 CWE Mapping

CWE ID	CWE-287: Improper Authentication
CWE Description	The software does not correctly implement authentication, allowing access to functionality or data to be unintentionally exposed.
Why This CWE?	The Samba protocol accepts inadequate authentication levels (CONNECT level instead of requiring SIGN or SEAL), which allows the connection to be hijacked without proper credential verification.

2.4 Exploitability Analysis in Lab Environment

Is the vulnerable service running?	YES — Port 445/tcp (CIFS/SMB) confirmed open in Nessus scan results
Is the port reachable from Kali?	YES — Kali Linux can reach 192.168.56.106 on port 445 (same Host-Only network)
Does it require auth we don't have?	NO — Attack requires no credentials; only a man-in-the-middle network position
Special conditions required?	YES — Attacker MUST be in a man-in-the-middle position between client and Samba server

Conclusion:

LIKELY EXPLOITABLE — with conditions. In this lab environment (Host-Only network), Kali Linux and Metasploitable2 are on the same network segment. This means a man-in-the-middle position is achievable using ARP poisoning tools such as Ettercap or arpspoof. However, exploitation requires a legitimate user (victim) to initiate an SMB connection to the Samba server. Since this is an isolated lab with no other users, exploitation would require simulating the victim's SMB connection. The CVSS score of 7.5 is appropriate — the AC:H metric correctly reflects the difficulty of achieving the MITM position.

3. Finding 2: SSL Version 2 and 3 Protocol Detection (POODLE)

3.1 CVE Information

CVE ID	CVE-2014-3566 (POODLE)
Vulnerability Name	POODLE — Padding Oracle On Downgraded Legacy Encryption
CVE Published Date	October 14, 2014
Affected Software	Any software supporting SSLv3 fallback — OpenSSL, SMTP, PostgreSQL, browsers
Source	CVE.org + NVD + CERT/CC VU#577193
Description (NVD)	The SSL protocol 3.0 uses nondeterministic CBC padding, which makes it easier for man-in-the-middle attackers to obtain cleartext data via a padding-oracle attack. This is an inherent design flaw in SSLv3 that cannot be patched — the protocol must be disabled entirely.

3.2 CVSS Score & Vector Breakdown

CVSS Version	CVSS v2.0 (original) / v3.x (enriched)
CVSS Base Score	3.4 — 9.8 (varies by context)
CVSS v2 Vector	AV:N/AC:M/Au:N/C:P/I:N/A:N (Score: 4.3 — Medium)
CVSS v3 Vector	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H (Score: 9.8 — Critical)

CVSS v3 Vector String Breakdown:

Metric	Value	Explanation
Attack Vector (AV)	Network (N)	Exploitable over the network — attacker intercepts SMTP/PostgreSQL traffic
Attack Complexity (AC)	Low (L)	No special conditions — SSLv3 session can be forced by any client
Privileges Required (PR)	None (N)	Attacker does not need any credentials on the target system
User Interaction (UI)	None (N)	No user action is required; attack works passively via MITM
Scope (S)	Unchanged (U)	Vulnerability limited to the affected service only
Confidentiality (C)	High (H)	Encrypted data (emails, DB queries, credentials) can be decrypted
Integrity (I)	High (H)	Attacker can inject data into the decrypted session
Availability (A)	High (H)	Can disrupt SSL/TLS communications entirely

3.3 CWE Mapping

CWE ID	CWE-327: Use of a Broken or Risky Cryptographic Algorithm
CWE Description	The software uses a broken or risky cryptographic algorithm that may allow an attacker to compromise the confidentiality of the data it is trying to protect.
Why This CWE?	SSLv3 uses a broken CBC padding scheme (nondeterministic) that is inherently vulnerable to padding oracle attacks. The cryptographic design of SSLv3 is fundamentally flawed and cannot be patched — only disabled. This perfectly maps to CWE-327.
Also Related To	CWE-326: Inadequate Encryption Strength — SSLv3 supports weak export-grade cipher suites (40-bit RC4, DES) that are trivially broken by modern hardware

3.4 Exploitability Analysis in Lab Environment

Is the vulnerable service running?	YES — Port 25/tcp (SMTP) and 5432/tcp (PostgreSQL) confirmed open and using SSLv3
Is the port reachable from Kali?	YES — Both ports accessible from Kali on same Host-Only network
Does it require auth we don't have?	NO — POODLE is a passive MITM attack requiring no credentials
Special conditions required?	YES — Must intercept active SSLv3 sessions; requires a victim to use the service
Practical Impact in Lab?	LIMITED — SMTP and PostgreSQL are rarely used actively in this lab setup, so there may be no live sessions to intercept

Conclusion:

LIKELY EXPLOITABLE — but with limited practical impact in this isolated lab. While SSLv3 is confirmed running on ports 25 and 5432, and an attacker on the same network segment can perform ARP poisoning for MITM, there must be an active encrypted session in progress for the POODLE attack to decrypt anything useful. In a real environment with active email servers and database clients, this would be highly critical. The CVSS score discrepancy (4.3 in v2 vs 9.8 in v3) illustrates perfectly why CVSS score alone does not reflect actual business risk.

4. Finding 3: VNC Server Weak Password

4.1 CVE Information

CVE ID	No CVE (Nessus Plugin ID: 61708)
Vulnerability Name	VNC Server Weak/Default Password — Insufficient Authentication Control
Why No CVE?	This is a configuration vulnerability, not a software flaw. The VNC software works as designed — the weakness is that the administrator configured a trivially guessable password ('password'). Configuration issues are generally tracked as CWE, not CVE.
Closest CVE Reference	CWE-521 (Weak Password Requirements) is the correct classification. No specific CVE for Metasploitable2 VNC default password.
Source	Nessus Plugin 61708 + MITRE CWE (cwe.mitre.org/data/definitions/521.html)
Description	The VNC server on port 5900 is configured with the trivially weak password 'password'. Nessus successfully authenticated using this password and confirmed full access. Any unauthenticated remote attacker can log in and gain full graphical desktop control of the system.

4.2 CVSS Score & Vector Breakdown

Since there is no official CVE for this specific finding, the CVSS score is calculated manually based on the vulnerability characteristics. This is a common analyst skill — calculating CVSS for findings without an assigned CVE.

CVSS Version	CVSS v3.1 (manually calculated)
CVSS Base Score	10.0 (CRITICAL)
CVSS Vector String	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS v3.1 Vector String Breakdown (Manually Calculated):

Metric	Value	Justification
Attack Vector (AV)	Network (N)	VNC port 5900 is accessible remotely over any network — no local access needed
Attack Complexity (AC)	Low (L)	No special conditions — just connect to port 5900 and type 'password'
Privileges Required (PR)	None (N)	Attacker needs zero prior credentials or account on the system
User Interaction (UI)	None (N)	Attack is fully automated — victim does not need to do anything
Scope (S)	Unchanged (U)	Access limited to the target system itself
Confidentiality (C)	High (H)	Full graphical desktop access = all files, data, credentials visible
Integrity (I)	High (H)	Attacker can create, modify, delete any files; install malware
Availability (A)	High (H)	Attacker can shut down, reboot, or fully disable the system

4.3 CWE Mapping

CWE ID	CWE-521: Weak Password Requirements
CWE Description	The product does not require that users should have strong passwords, which makes it easier for attackers to compromise user accounts.
Why This CWE?	The VNC server allows authentication with the extremely weak password 'password' — a single common dictionary word. There are no minimum password complexity requirements enforced, no lockout policy after failed attempts, and no multi-factor authentication. This is a textbook CWE-521 weakness.
Also Related To	CWE-287: Improper Authentication — The system's authentication mechanism does not adequately prevent unauthorized access
CAPEC Reference	CAPEC-70: Try Common (Default) Usernames and Passwords — directly describes this attack pattern

4.4 Exploitability Analysis in Lab Environment

Is the vulnerable service running?	YES — VNC confirmed running on port 5900/tcp by Nessus scan
Is the port reachable from Kali?	YES — Port 5900 accessible on same Host-Only network (192.168.56.x)
Does it require auth we don't have?	NO — Password is 'password' (confirmed by Nessus login)
Special conditions required?	NONE — Simply connect with any VNC client and type 'password'
Verification Method	Run: vncviewer 192.168.56.106 and enter password 'password' to verify access

Conclusion:

DEFINITELY EXPLOITABLE — No conditions required. This is the most immediately dangerous vulnerability in the lab environment. Unlike the Samba Badlock and POODLE findings which require a MITM position and an active session, the VNC weak password can be exploited directly and immediately by any attacker who can reach port 5900. The attacker simply opens a VNC client, connects to 192.168.56.106:5900, types 'password', and has full graphical desktop control. CVSS 10.0 is fully justified.

5. Summary & Comparison

The following table provides a comparative overview of the three vulnerabilities analysed in this lab:

Finding	CVE	CVSS	CWE	AV / AC	Exploitable in Lab?
Samba Badlock	CVE-2016-2118	7.5 HIGH	CWE-287	N / H	LIKELY (needs MITM)
SSL POODLE	CVE-2014-3566	9.8 CRITICAL	CWE-327	N / L	LIKELY (needs active session)
VNC Weak PW	No CVE	10.0 CRITICAL	CWE-521	N / L	DEFINITELY EXPLOITABLE

5.1 Key Learning: CVSS Score $\neq$ Actual Business Risk

This lab demonstrates an important principle: a high CVSS score does not automatically mean a vulnerability is immediately exploitable or poses the highest business risk in a specific environment.

- VNC Weak Password (CVSS 10.0): Immediately and trivially exploitable — zero conditions required. This is both high CVSS AND high actual risk.
- SSL POODLE (CVSS 9.8): High CVSS but lower practical risk in this lab — requires active encrypted sessions to intercept, which may not exist in an isolated lab environment.
- Samba Badlock (CVSS 7.5): Lower CVSS but still significant — the AC:H metric correctly reflects the difficulty of the MITM attack but does not mean it is impossible.

The key takeaway is that analysts must always contextualise CVSS scores against the actual environment — considering network topology, whether services are active, whether preconditions can be met, and what the actual business impact would be.